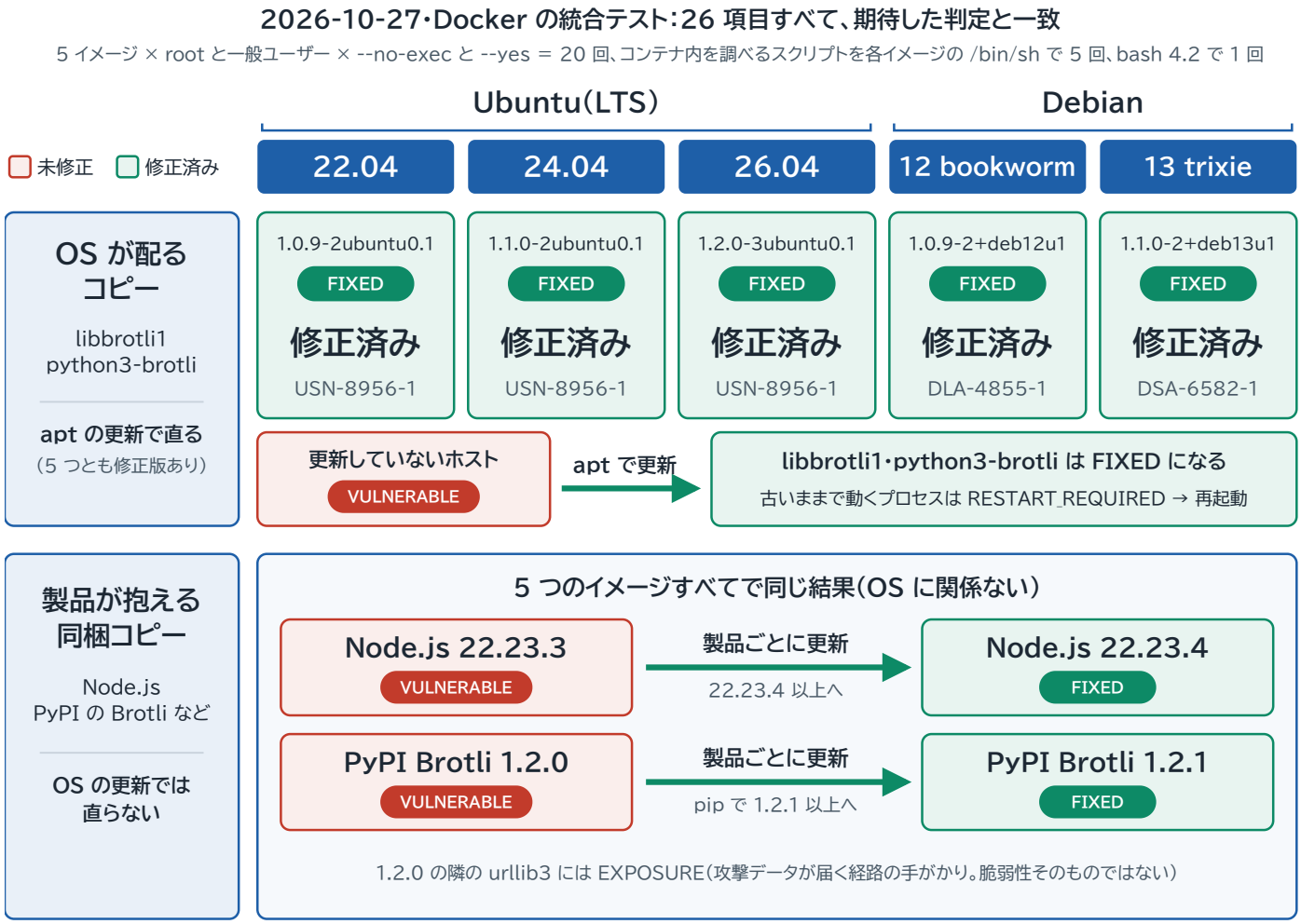
図解 02　5 つの OS での点検結果と読み方 — brotli-cve-check —



この1枚の読み方

1. **行が「どこにあるコピーか」、列が OS。**上の行（OS が配るコピー）は、2026-10-27 に作ったイメージでは 5 つとも **FIXED**。Ubuntu は 2026-10-26 に 22.04・24.04・26.04・26.10 を修正し（USN-8956-1）、Debian は 12・13 を修正済み。その後に更新していないホストでは VULNERABLE なので、apt で更新し、それを使うものを再起動する。下の行（同梱コピー）は OS に関係なく同じ。テストでは未修正版をわざと入れたので、どの実行も終了コード 1 になる（意図したとおりの結果）。
2. **結果は最後の「要約」4 行から読む。**「更新が必要なもの」= VULNERABLE と LIKELY_VULNERABLE、「再起動が必要なもの」= RESTART_REQUIRED、「人の確認が必要なもの」= NO_FIX_AVAILABLE・VENDORED_COPY・UNKNOWN・LIKELY_FIXED、「走査しなかった範囲」。例：Ubuntu 24.04 のイメージの出力例（docs/sample-output.md）は「更新が必要 2・再起動が必要 0・人の確認が必要 0」で、2 件はわざと入れた Node.js 22.23.3 と PyPI の Brotli 1.2.0。
3. **終了コード 0 は「安全」ではない。**意味は「走査した範囲で対応が必要なものが見つからなかった」だけ。見つけたデコーダーに攻撃者のデータが届くかは判定せず（EXPOSURE は手がかり）、侵入の有無も調べない。このテストで使った既知データは 2026-10-27 時点のスナップショット（2026-10-26 のデータでは Ubuntu を NO_FIX_AVAILABLE と出していた。設計メモ 2.1）。

OS のコピーはどの OS も apt で直る。同梱コピーは製品ごとに更新するまで残る。

処方箋　apt で更新して使っているものを再起動し、もう一度点検して、要約の「更新が必要なもの」に残った同梱コピーを製品ごとに更新する。